

DVSA Vulnerability Discovery and Remediation

ICS-344 Information Security Course Project

Term 252

Project Context

This report summarizes the DVSA vulnerability discovery and remediation project for the ICS-344 controlled university lab environment. DVSA was deployed in a non-production AWS account in **us-east-1**. All evidence and commands in this repository are intended for the course assignment only. Sensitive values such as JWTs, AWS account IDs, credentials, and private identifiers are redacted.

Architecture Summary

The DVSA application uses a serverless AWS architecture:

- Static frontend hosted on Amazon S3.
- Amazon API Gateway as the public API entry point.
- AWS Lambda functions for backend workflows.
- DynamoDB, S3, SQS, SES, CloudWatch, CloudTrail, and IAM for persistence, messaging, observability, and permissions.

Repository Evidence Map

Area	Path	Purpose
Writeups	<code>vulnerabilities/lesson-*</code>	Lesson-specific reproduction notes, redacted requests, and report sources.
Fixes	<code>fixes/lesson-*</code>	Before/after remediation notes, code examples, and policy examples.
Screenshots	<code>screenshots/lesson-*</code>	Browser, terminal, AWS Console, CloudWatch, and IAM evidence.
Diagrams	<code>diagrams/</code>	Architecture, sequence, and blast-radius diagrams.

Lesson Summary

No.	Vulnerability	Root Cause	Fix Theme
1	Event Injection	Unsafe handling of attacker-controlled serialized input.	Safe JSON parsing, schema validation, and removal of executable deserialization.
2	Broken Authentication	JWT claims trusted without complete server-side verification.	Verify signature, issuer, audience, expiry, and trusted subject before using identity.
3	Sensitive Data Exposure	Receipt data or links exposed outside the intended authorization boundary.	Ownership checks and short-lived authorized receipt access.
4	Insecure Cloud Configuration	S3 receipt bucket and trigger path allowed unsafe object handling.	Block public access, restrict bucket policy, and validate object source/key.
5	Broken Access Control	Normal users could reach privileged order update behavior.	Role checks, admin-only authorization, and narrower Lambda invoke permissions.
6	Denial of Service	Repeated billing requests could consume backend capacity.	API throttling, idempotency, and controlled request handling.
7	Over-Privileged Function	Receipt Lambda role allowed permissions broader than needed.	Least-privilege IAM policy for receipt email and logging only.
8	Logic Vulnerability	Non-atomic order state transitions created a race condition.	Conditional writes, transactions, and workflow locking.
9	Vulnerable Dependencies	Unsafe dependency behavior enabled dangerous deserialization.	Remove/replace risky packages and scan/pin dependencies.
10	Unhandled Exceptions	Backend exceptions leaked implementation details to clients.	Input validation and centralized safe error handling.

Lesson 6: Denial of Service

Goal and Root Cause

The billing endpoint should process legitimate checkout requests without allowing duplicate or concurrent request bursts to exhaust Lambda/API Gateway capacity. The observed weakness was insufficient request protection for repeated billing attempts.

Evidence

The repository includes PowerShell evidence for a controlled serialized request test and a controlled 10-job parallel request test. The parallel test produced mixed HTTP 200, 500, and 502 responses, which supports the availability impact claim. CloudWatch, Lambda metrics, and API Gateway throttling screenshots are stored under `screenshots/lesson-06/`.

Fix and Verification

The remediation is API Gateway throttling plus backend idempotency/rate-control logic for billing. Post-fix verification should show excess requests rejected or throttled cleanly while normal checkout still works.

Lesson 7: Over-Privileged Function

Goal and Root Cause

The receipt email function should have only the permissions needed to send receipts and write logs. The observed weakness was broad execution-role permissions, especially around SES and representative wildcard service access.

Evidence

Evidence includes the Lambda function page, execution role page, broad SES policy evidence, IAM Policy Simulator checks, post-fix simulator checks, and normal order workflow screenshots under `screenshots/lesson-07/`.

Fix and Verification

The remediation replaces broad IAM permissions with a least-privilege policy. Verification uses IAM Policy Simulator denial results for unnecessary actions and confirms the normal order workflow still works.

Structured Analysis

Lesson	Intended Rule	Deviation Class	Verification
Lesson 6	Billing must degrade safely under duplicate or burst requests.	Security-relevant misuse	Throttling evidence and normal workflow confirmation.
Lesson 7	Lambda role must allow only required receipt workflow actions.	Accidental misconfiguration	IAM simulator and normal workflow evidence.

Key Takeaways

- Serverless security depends on both code correctness and cloud-service configuration.
- Authentication and authorization must be enforced in backend logic, not only in the browser.
- IAM least privilege reduces blast radius when a function is abused.
- Availability controls such as throttling and idempotency are part of secure design.
- Error handling should protect users from internal details while preserving useful CloudWatch diagnostics.

Remaining Manual Checks

- Confirm the exact final AWS configuration matches the redacted policy and throttling examples in the repository.
- Review imported external videos in `videos/external-unassigned/` and assign them to lessons if their content is confirmed.
- Ensure every screenshot used in the submitted report is readable and contains no real secrets.